

SEGURANÇA DIGITAL • 6º SEMESTRE

Kali Linux: Linha de comando

```
1 0 1 0 1 1
1 1 0 1 1 0
0 0 0 1 0 0
0 1 0 1 0 0
0 0 1 0 0 1
1 1 0 0 0 0
1 0 0 0 1 1
1 1 0 1 0 0
0 1 1 0 1 1
```

Aula 05 • Do reconhecimento ao terminal: o ambiente onde a varredura acontece

Sistemas de Informação • Ensino noturno • 18h25-22h05

Prof. José Carlos Neto • j.neto@ufn.edu.br

O que vimos na Aula 04

Antes de entrar no terminal, um resumo do que já sabemos sobre varredura e enumeração.

Handshake TCP e estados de porta

SYN-ACK, ACK — e por que uma porta aparece aberta, fechada ou filtrada.

Tipos de scan e o Nmap

SYN scan (-sS), Connect scan (-sT), detecção de versão (-sV) e flags combinadas.

Banner grabbing com nc

Conectar direto num serviço e ler o que ele revela sobre si mesmo.

NAT e visibilidade externa

Por que um testador de fora só enxerga o que tem port forwarding.

Por que o SYN scan precisa de sudo?

```
$ nmap -sS alvo  
TIP: root privileges  
required.
```

Na Aula 04 rodamos `nmap -sS` e alguns scripts do NSE exigindo privilégio administrativo.

Hoje vamos entender de verdade o que é esse privilégio, como o Linux organiza permissões e arquivos – e por que isso importa para qualquer ferramenta de segurança.

0 que veremos hoje

Do sistema de arquivos ao terminal em ação – sempre ligando com o que já foi usado na Aula 04.

- | | | | |
|----|---|----|---|
| 01 | Como a aula vai funcionar hoje (blocos e intervalo) | 07 | Redirecionamento, pipes e processos |
| 02 | O que é o Kali Linux e por que é a distro padrão em pentest | 08 | Logs, espaço em disco e compactação de arquivos |
| 03 | Sistema de arquivos: estrutura FHS e navegação | 09 | Pacotes (apt), comandos de rede e SSH |
| 04 | Manipulação de arquivos, wildcards, find/locate e links | 10 | Atividade prática guiada: repetindo o scan da Aula 04 no terminal |
| 05 | Permissões, usuários, grupos e privilégio (sudo x su) | 11 | Atividade em duplas: mini shell-script |
| 06 | Ajuda, histórico e produtividade no terminal | | |

Como a aula vai funcionar hoje

Quase 4 horas de aula – vamos alternar teoria, exemplos e prática em blocos, com uma pausa no meio.

BLOCO 1

FUNDAMENTOS

Kali Linux, sistema de arquivos, navegação, wildcards, permissões, usuários e privilégio.

BLOCO 2

LINHA DE COMANDO

Ajuda, histórico, redirecionamento, pipes, processos, logs, disco, pacotes e rede.

INTERVALO

15 MIN

Uma pausa no meio da aula para descansar antes da parte prática.

BLOCO 3

PRÁTICA

Atividade guiada repetindo o scan da Aula 04, e exercício em duplas.

O objetivo é sair de hoje sabendo navegar e operar um terminal Kali com confiança – sem decorar comandos de cor.

Experiência formativa

O que estudaremos?

O Kali Linux como ambiente de trabalho: sua estrutura de diretórios, navegação e manipulação de arquivos via linha de comando.

O que aprenderemos?

Como o sistema operacional organiza permissões e privilégios – e por que ferramentas como o Nmap dependem disso para funcionar.

Sobre o que refletiremos?

Por que dominar o terminal é o que separa quem só roda comandos prontos de quem entende o que está fazendo.

Competências e objetivos

COMPETÊNCIA

Operar o sistema de arquivos e a linha de comando do Linux de forma segura, compreendendo o papel das permissões e do usuário root nas ferramentas de segurança.

OBJETIVOS

- Navegar e manipular arquivos e diretórios no terminal
- Interpretar e alterar permissões (rwx, chmod, chown)
- Usar redirecionamento, pipes e comandos de rede básicos
- Reproduzir no terminal os comandos vistos na Aula 04

0 que é o Kali Linux

Uma distribuição Debian voltada especificamente para testes de invasão e auditoria de segurança.

Mantida pela Offensive Security

Distro oficial usada em certificações como OSCP e em pentests profissionais no mundo todo.

Ferramentas pré-instaladas

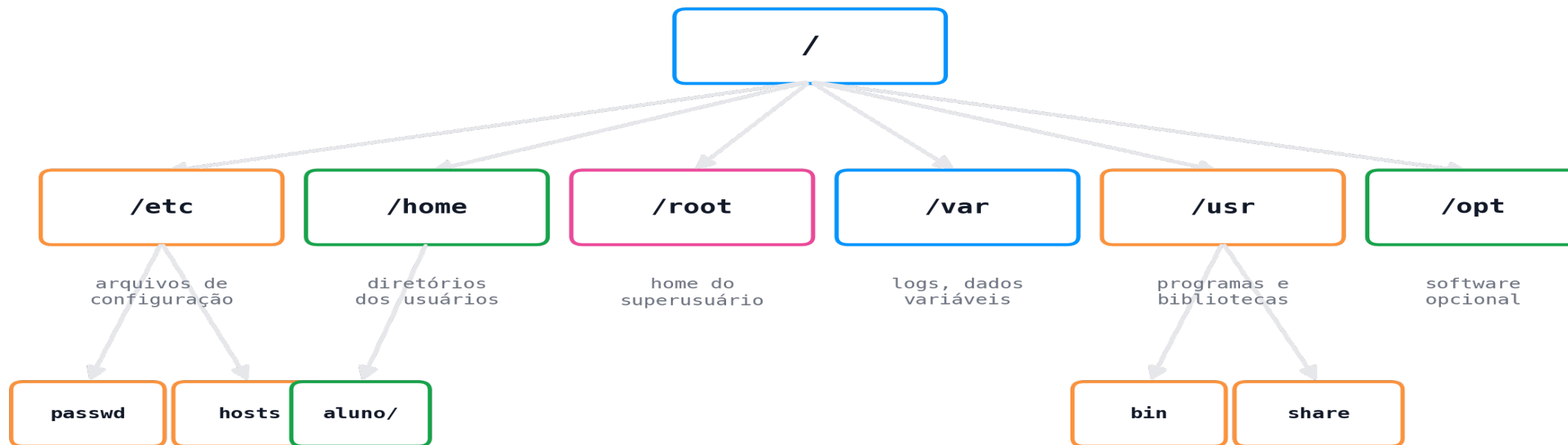
Nmap, Wireshark, nikto, gobuster, enum4linux – tudo que usamos na Aula 04 já vem pronto.

Voltada para reconhecimento e exploração

Organizada por fase do teste de invasão: coleta, varredura, exploração, pós-exploração.

A estrutura do sistema: FHS

Filesystem Hierarchy Standard – todo Linux organiza seus arquivos a partir de uma raiz única (/).



Navegação básica

Os primeiros comandos que qualquer sessão de terminal precisa.

```
pwd
```

Mostra o diretório atual (print working directory)

```
ls
```

Lista o conteúdo do diretório atual

```
ls -la
```

Lista tudo, incluindo ocultos, em formato detalhado (permissões, dono, tamanho)

```
cd /caminho
```

Muda para o diretório informado

```
cd ..
```

Sobe um nível no diretório

```
cd ~
```

Vai direto para o diretório home do usuário

Manipulação de arquivos e diretórios

Criar, copiar, mover, remover e visualizar conteúdo – a base de qualquer trabalho no terminal.

mkdir pasta

Cria um novo diretório

touch arq.txt

Cria um arquivo vazio

cp origem destino

Copia um arquivo ou diretório (-r)

mv origem destino

Move ou renomeia um arquivo

rm arquivo

Remove um arquivo (-r para diretórios)

cat arquivo

Exibe todo o conteúdo do arquivo

less arquivo

Exibe o conteúdo com rolagem/paginação

nano / vim arquivo

Abre editores de texto no terminal

Wildcards e globbing

Padrões para seleccionar vários arquivos de uma vez, sem digitar nome por nome.

*

Qualquer sequência de caracteres

```
ls *.txt
```

?

Um único caractere qualquer

```
ls arquivo?.txt
```

[abc]

Qualquer caractere dentro do conjunto

```
ls img[12].png
```

{a,b}

Expansão de chaves (brace expansion)

```
cp arquivo.{txt,bak} .
```

Encontrando arquivos: find e locate

Buscar em toda a árvore de diretórios por nome, tipo, data ou permissão.

```
find / -name "*.conf"
```

Busca por nome a partir da raiz do sistema

```
find . -type f -mtime -7
```

Arquivos modificados nos últimos 7 dias

```
find / -perm -4000 2>/dev/null
```

Arquivos com bit SUID – relevante para escalonamento de privilégio

```
locate nome
```

Busca rápida usando um índice pré-construído (updatedb)

Guardem o comando do SUID – ele volta com tudo quando falarmos de exploração de vulnerabilidades.

Links simbólicos

Um atalho que aponta para outro arquivo ou diretório, sem duplicar o conteúdo.

```
$ ln -s /caminho/original /caminho/atalho
```

ln -s alvo link

Cria um link simbólico chamado 'link' apontando para 'alvo'

ls -l

Mostra o link com uma seta (→) indicando o alvo original

rm link

Remove apenas o link – o arquivo original continua intacto

Permissões: rwx e notação octal

Cada arquivo tem permissões de leitura (r), escrita (w) e execução (x) para dono, grupo e outros.



chmod, chown – e por que o Nmap pede sudo

chmod

Altera as permissões de um arquivo.

```
chmod 754 script.sh
```

```
chmod +x script.sh
```

chown

Altera o dono e/ou grupo de um arquivo.

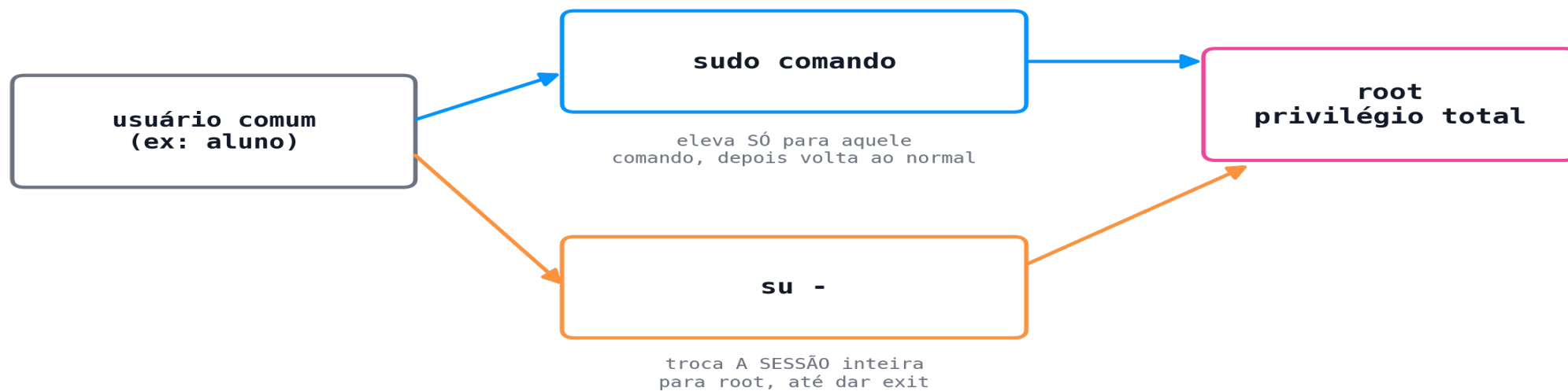
```
chown usuario:grupo arquivo
```

LIGAÇÃO COM A AULA 04

Um SYN scan (-sS) monta pacotes TCP brutos – algo que só o kernel permite a processos com privilégio de root. É por isso que nmap -sS e vários scripts do NSE pedem sudo: eles precisam de um nível de acesso que o dono comum do sistema não tem por padrão.

Usuários, grupos e privilégio

`sudo` e `su` resolvem o mesmo problema – elevar privilégio – de formas diferentes.



`whoami`

`id`

`groups`

`sudo adduser aluno`

Pedindo ajuda ao próprio sistema

Antes de pesquisar no Google, o Linux já documenta os comandos.

```
man nmap
```

Abre o manual completo do comando (q para sair)

```
nmap --help
```

Mostra um resumo rápido das opções de uso

```
apropos porta
```

Busca comandos relacionados a um termo

```
man -k rede
```

Equivalente a apropos

Histórico, atalhos e aliases

Pequenos recursos que economizam digitação – e evitam erros em comandos longos de rede.

```
history
```

Lista os comandos já executados na sessão

```
Ctrl + R
```

Busca reversa no histórico de comandos

```
Tab
```

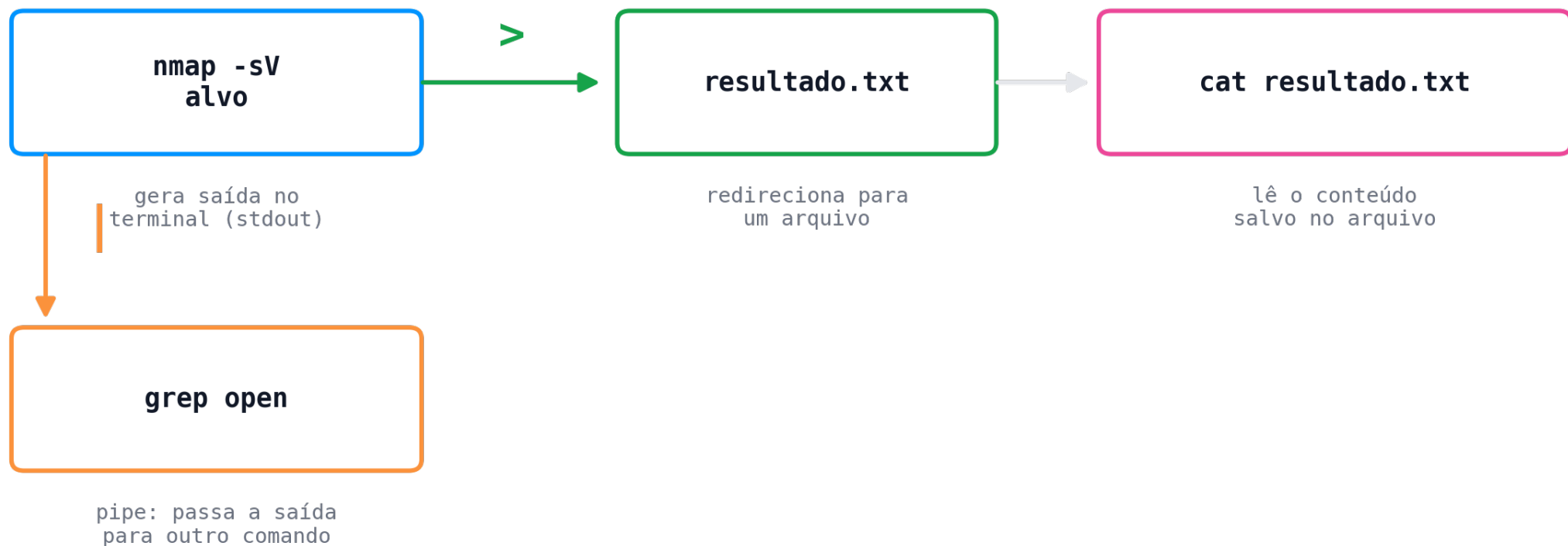
Autocompleta comandos, arquivos e caminhos

```
alias nm='nmap -sV -T4'
```

Cria um atalho para um comando longo

Redirecionamento e pipes

Conectar a saída de um comando a um arquivo – ou à entrada de outro comando.



-oN também é redirecionamento

O que a Aula 04 chamou de 'salvar a saída do scan' é exatamente o conceito que acabamos de ver.

```
$ nmap -oN saida.txt alvo
```

```
nmap -oN saida.txt
```

Formato nativo do Nmap – equivalente a usar > por dentro

```
nmap alvo > saida.txt
```

Redirecionamento genérico do shell – funciona com qualquer comando

```
nmap alvo | grep open
```

Pipe – filtra a saída em tempo real, sem salvar em arquivo

Processos

Todo programa em execução – inclusive um scan em andamento – é um processo.

ps

Lista os processos em execução na sessão atual

ps aux

Lista todos os processos do sistema, de todos os usuários

top / htop

Monitor interativo de processos em tempo real (CPU, memória)

kill PID

Encerra um processo pelo seu identificador (PID)

comando &

Executa um comando em segundo plano (background)

Lendo arquivos grandes e logs

Nem sempre queremos ver o arquivo inteiro – especialmente logs de segurança.

```
head -n 20 arquivo
```

Mostra as primeiras 20 linhas do arquivo

```
tail -n 20 arquivo
```

Mostra as últimas 20 linhas do arquivo

```
tail -f /var/log/auth.log
```

Acompanha um log em tempo real, linha a linha

```
wc -l resultado.txt
```

Conta linhas – útil para saber quantas portas o grep encontrou

Espaço em disco

Verificar espaço antes de salvar grandes capturas de tráfego ou resultados de scan.

```
df -h
```

Espaço livre e usado por partição, em formato legível

```
du -sh pasta/
```

Tamanho total de uma pasta específica

```
du -sh * | sort -h
```

Ordena o tamanho das pastas do menor para o maior

Compactação e arquivamento

Empacotar evidências e resultados de um teste de invasão para entrega ou backup.

```
tar -czvf pacote.tar.gz pasta/
```

Compacta um diretório inteiro em um único arquivo

```
tar -xzvf pacote.tar.gz
```

Extrai o conteúdo de um pacote .tar.gz

```
zip -r pacote.zip pasta/
```

Compacta em formato .zip, mais comum fora do mundo Linux

```
unzip pacote.zip
```

Extrai o conteúdo de um arquivo .zip

Gerenciamento de pacotes (apt)

As ferramentas complementares vistas na Aula 04 (gobuster, nikto) chegam ao sistema assim.

```
apt update
```

Atualiza a lista de pacotes disponíveis nos repositórios

```
apt upgrade
```

Atualiza os pacotes já instalados para a versão mais recente

```
apt install gobuster
```

Instala uma ferramenta específica

```
apt remove pacote
```

Remove um pacote instalado

```
sudo apt install gobuster nikto → agora as ferramentas da Aula 04 estão disponíveis no seu Kali.
```

Comandos de rede básicos

Antes de rodar o Nmap, o terminal já oferece um primeiro nível de reconhecimento.

```
ip a
```

Mostra as interfaces de rede e endereços IP da máquina

```
ss -tuln
```

Lista as portas e conexões abertas localmente (substitui o netstat)

```
ping alvo
```

Testa conectividade básica (ICMP) com um host

```
curl / wget URL
```

Faz requisições HTTP direto do terminal

```
nc host porta
```

Conecta manualmente a um serviço – banner grabbing

nc é o mesmo banner grabbing da Aula 04

O comando que você já usou lá é, na verdade, um comando de rede padrão do terminal Linux.

```
$ nc 192.168.1.20 22
SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.4
```

netcat (nc) é uma ferramenta genérica de conexão TCP/UDP. Quando apontamos para a porta 22, o serviço SSH do outro lado se apresenta automaticamente – esse texto de apresentação é o banner. É exatamente essa técnica, e não mágica de ferramenta de pentest, que estava por trás do banner grabbing visto na aula passada.

Conectando a hosts remotos: SSH

O mesmo serviço enumerado na porta 22 na Aula 04 também serve para administrar sistemas.

```
ssh usuario@host
```

Conecta a um host remoto via SSH

```
ssh -p 2222 usuario@host
```

Especifica uma porta diferente da padrão (22)

```
scp arquivo usuario@host:/destino
```

Copia um arquivo para o host remoto

```
ssh-keygen
```

Gera um par de chaves para autenticação sem senha

Lembra do banner SSH-2.0-OpenSSH que enumeramos na porta 22? É esse serviço que o ssh usa para conectar.

Variáveis de ambiente e PATH

Como o terminal sabe onde encontrar o executável de um comando como nmap.

```
$ echo $PATH  
/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
```

Variável de ambiente

Um valor nomeado disponível para os programas da sessão (ex.: \$HOME, \$USER, \$PATH)

PATH

Lista de diretórios onde o shell procura executáveis – por isso digitar nmap funciona de qualquer pasta

export VAR=valor

Define uma variável de ambiente na sessão atual

INTERVALO

15 minutos – depois voltamos com a prática no terminal

```
001100001101100100011110110010  
011110010100010111110010110011  
101111001010110111010010101100
```

Preparando o ambiente de trabalho

Antes de rodar o scan, vamos organizar um diretório de trabalho com permissões corretas.

1

```
mkdir aula05 && cd aula05
```

Cria e entra em um diretório de trabalho

2

```
touch script.sh
```

Cria um arquivo vazio

3

```
chmod +x script.sh
```

Dá permissão de execução ao arquivo

4

```
ls -la
```

Confirma o resultado – o x agora aparece nas permissões

Repetindo o scan da Aula 04

Agora com sudo, redirecionamento e o alvo de prática autorizado scanme.nmap.org.

```
$ sudo nmap -sS -T4 -oN resultado.txt scanme.nmap.org
```

sudo

Privilégio de root – necessário para o SYN scan (-sS)

-sS -T4

Tipo de scan e velocidade, como na Aula 04

-oN resultado.txt

Redireciona a saída para um arquivo – o que vimos hoje

Lendo e filtrando o resultado

O arquivo salvo agora pode ser lido e filtrado com os comandos vistos hoje.

```
$ cat resultado.txt  
$ grep open resultado.txt  
22/tcp open ssh
```

cat mostra o arquivo inteiro; grep open filtra só as linhas com portas abertas. É o mesmo princípio do pipe (|), só que aplicado a um arquivo já salvo em vez da saída em tempo real.

Banner grabbing, salvando a saída

Combinando nc (rede) com > (redirecionamento) – dois conceitos vistos hoje juntos.

```
$ nc scanme.nmap.org 22 > banner.txt
```

O nc se conecta na porta 22, recebe o banner do serviço SSH e, em vez de mostrar na tela, grava direto em banner.txt. Documentar assim é essencial em um teste de invasão real.

Em duplas: mini shell-script

Cada dupla escreve, em um arquivo de texto, uma sequência de comandos que resolva o desafio abaixo.

1. Cria um diretório chamado recon
2. Entra nesse diretório
3. Roda um scan com nmap salvando a saída em um arquivo
4. Filtra e imprime só as linhas com portas abertas usando grep

10 minutos em duplas – depois cada dupla compartilha sua sequência de comandos com a turma.

Exercícios de fixação

Resolvam individualmente – revisamos as respostas na próxima aula.

- 1 Diferencie caminho absoluto e caminho relativo, com um exemplo de cada.
- 2 O que significa a permissão `rwxr-xr--` em notação octal?
- 3 Por que o comando `nmap -sS` exige `sudo`, mas o `nmap -sT` não?
- 4 Reescreva `nmap alvo > saida.txt` usando a flag nativa do próprio Nmap.
- 5 Cite dois comandos de rede vistos hoje e o que cada um revela sobre um host.
- 6 Qual a diferença prática entre `sudo` comando e `su -`?
- 7 Escreva um comando `find` que procure, a partir de `/`, arquivos com bit SUID.

Glossário da aula

Shell

Interpretador de comandos do terminal (ex.: bash)

FHS

Filesystem Hierarchy Standard – estrutura padrão de diretórios do Linux

Wildcard

Padrão (*, ?, []) que representa vários nomes de arquivo de uma vez

Link simbólico

Atalho que aponta para outro arquivo ou diretório

Permissão (rwx)

Direitos de leitura, escrita e execução sobre um arquivo

SUID

Bit de permissão que executa um programa com o privilégio do dono do arquivo

sudo

Eleva privilégio apenas para um comando, depois volta ao normal

su -

Troca toda a sessão para outro usuário (geralmente root), até dar exit

Glossário da aula (continuação)

Pipe (|)

Encadeia a saída de um comando como entrada de outro

Redirecionamento (>)

Envia a saída de um comando para um arquivo

Processo

Instância em execução de um programa

PATH

Variável que lista onde o shell procura executáveis

man

Manual completo de um comando, aberto diretamente no terminal

Alias

Atalho definido pelo usuário para um comando (ou sequência de flags)

tar / zip

Formatos de compactação e arquivamento de arquivos e pastas

SSH

Protocolo para acessar e administrar um host remotamente, com segurança

Próxima aula

Voltando ao fio condutor da Aula 04: de portas abertas a vulnerabilidades.

Aprofundar a análise de versões de serviço em busca de vulnerabilidades conhecidas (CVE)

Introduzir bancos de dados de vulnerabilidades (NVD, Exploit-DB) e como consultá-los

Relacionar os resultados de enumeração com a etapa de exploração

Até a próxima aula: guardem o resultado.txt e o banner.txt salvos hoje – vamos usá-los como ponto de partida para procurar vulnerabilidades reais.

O que vimos hoje

Recapitulando os pilares da Aula 05.

- Kali Linux e o FHS
- Navegação, wildcards, find/locate e links
- Permissões, usuários, grupos e privilégio
- `sudo` x `su -` e a ligação com o Nmap
- `man`, histórico e produtividade no terminal
- Redirecionamento, pipes e processos
- Logs, disco e compactação de arquivos
- Pacotes (apt), rede e SSH
- Reprodução do scan da Aula 04 no terminal
- Banner grabbing com nc e redirecionamento

1 0 0 1 1 0
0 0 1 0 1 0
1 0 1 0 1 1
0 1 1 0 0 0
0 1 0 1 0 0
1 0 0 0 1 1
1 0 0 0 0 0
1 1 0 0 1 1
1 1 0 0 0 0

ENCERRAMENTO

Dúvidas?

Prof. José Carlos Neto

j.neto@ufn.edu.br